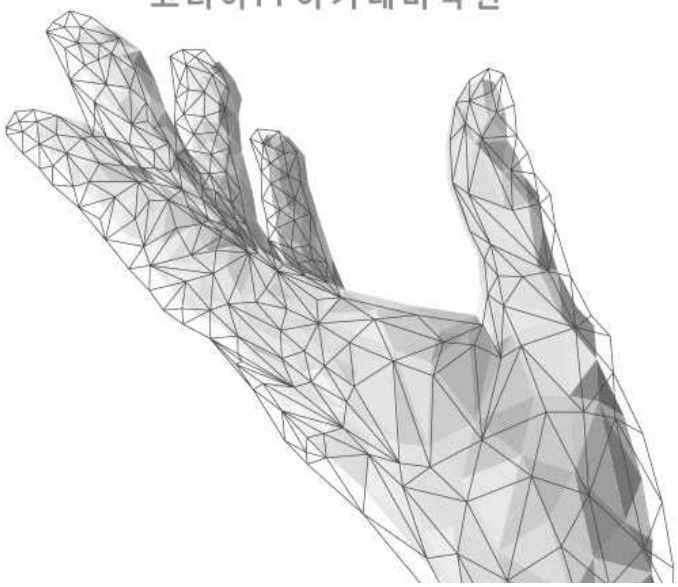
DB 보안 구축

KOREA
코리아IT아카데미학원



class	정보보안 산업기사 취득과정 A
name	조채언

목 차

Ⅰ. 데이터베이스 보안 구현 준비 ····· 3

가. 데이터베이스 구현 절차 ····· 3

나. 데이터베이스 구현을 위한 일정 계획 수립 과정 ····· 5

Ⅱ. SQL 쿼리 작성 ····· 8

Ⅲ. 데이터베이스 보안 구현 ····· 9

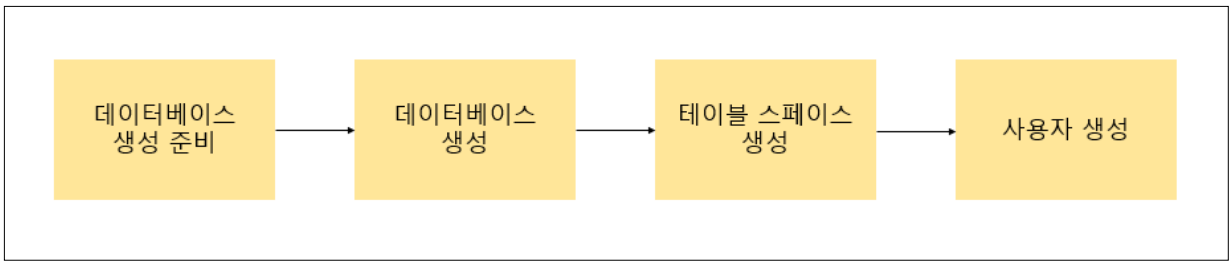
□ 데이터베이스 구현 방법 수행 ····· 9

□ 데이터베이스 암호화 주안점 수행 ····· 13

Ⅳ. 데이터베이스 보안 구현 테스트 ····· 18

Ⅰ. 데이터베이스 보안 구현 준비

가. 데이터베이스 구현 절차



1. 데이터베이스 생성 준비

데이터베이스 구현 작업을 실시하기 전에 관련 산출물이나 도구, 서버의 상태 등을 확인한다.

- **설계 산출물 검토**: 논리/물리 데이터 모델링(ERD), 데이터 사전, 엔티티 정의서 등을 최종 확인한다.
- **스토리지 산정**: 데이터의 초기 용량과 향후 1~3년간의 증가율을 계산하여 디스크 공간을 확보한다.
- **파라미터 설정**: DBMS의 메모리 구조(SGA, PGA 등), 프로세스 수, 문자 집합(UTF-8 등)을 결정한다.
- **백업 및 로그 전략**: 아카이브 로그 모드 설정 여부와 백업본이 저장될 물리적 경로를 미리 지정한다.

2. 데이터베이스 생성

서버의 명령어나 SQL을 이용하여 데이터베이스를 생성하고 구현한다.

- **인스턴스 기동**: 환경 변수 설정 후 DB 엔진을 기동한다.
- **Control File 및 Log File 생성**: DB의 상태 정보를 담는 컨트롤 파일과 변경 이력을 기록하는 리두 로그(Redo Log) 파일의 위치와 크기를 지정한다.
- **데이터 딕셔너리 생성**: 시스템 테이블(Catalog)을 생성하여 DB 스스로가 자신을 관리할 수 있는 메타데이터 구조를 만든다.

3. 테이블 스페이스 생성

테이블 스페이스(Table Space)는 데이터베이스 객체가 실제로 저장되는 물리적인 공간을 의미한다.

- **유형별 분리**
  - **System**: 관리용 데이터 저장.
  - **Data**: 실제 서비스 데이터 저장.
  - **Index**: 검색 속도 향상을 위한 인덱스 전용 공간 (데이터와 인덱스를 물리적 디스크로 분리하면 I/O 성능이 대폭 향상됩니다).
  - **Temporary/Undo**: 정렬 작업이나 트랜잭션 취소(Rollback)를 위한 임시 공간.
- **관리 방식**: Extent 관리 방식(Local or Dictionary)과 Block 크기(8KB, 16KB 등)를 설정하여 단편화(Fragmentation)를 방지합니다.
- **Raw Device vs File System**: 언급하신 대로 성능을 위해 OS 커널을 거치지 않는 Raw Device를 쓰기도 하지만, 최근에는 관리 편의성을 위해 고성능 파일 시스템이나 ASM(Automatic Storage Management)을 주로 사용합니다.

4. 사용자 생성

데이터베이스에 접속하여 사용하게 되는 사용자 ID를 생성하고 각 사용자별로 권한을 설정하는 단계이다.

- **스키마(Schema) 정의**: 각 사용자(User)가 소유하게 될 객체의 집합체인 스키마를 할당합니다.
- **권한 분류**
  - **시스템 권한 (System Privileges)**: CREATE TABLE, CREATE SESSION 등 DB 자체에 접근하는 권한.
  - **객체 권한 (Object Privileges)**: 특정 테이블에 대한 SELECT, INSERT, UPDATE 등 데이터 조작 권한.
- **Role(롤) 활용**: 다수의 사용자에게 일일이 권한을 부여하는 대신, '개발자용', '운영자용' 등 역할(Role)을 만들어 묶음으로 관리하면 훨씬 효율적입니다.
- **쿼터(Quota) 할당**: 특정 사용자가 테이블 스페이스의 용량을 무한정 사용하지 못하도록 최대 사용 가능 용량을 제한합니다.

나. 데이터베이스 구현을 위한 일정 계획 수립 과정

1. 일정관리 계획 수립

목표한 기간 내에 프로젝트를 완수하기 위해서는 정확한 일정을 세우고, 그 일정에 따라 프로젝트를 진행한다.

(1) 일정 관리 계획 수립 목적을 수립한다. 목적은 다음과 같은 개념을 가지고 작업한다.

(가) 일정은 언제까지 일을 끝내겠다는 약속이다.
(나) 프로젝트 팀원에게 자신의 업무가 프로젝트에 얼마나 기여하는지를 보여 줌으로써 모든 팀 구성원들을 격려하기 위함이다.
(다) 팀원에게 프로젝트 진행 상황을 추적하고 작업 활동을 관리 가능한 단위로 쪼개는 도구를 제공하기 위함이다.

(2) 일정 관리의 중요성을 분석한다.

(가) 일정은 일종의 예측이므로 잘 운영하는 것이 필요하다.
(나) 환경(범위 및 우선순위 등)이 변할 수 있음에 주의한다.
(다) 신중하게 기획할 필요가 있다.

2. 활동 정의

(1) 작업 활동을 분석한다.

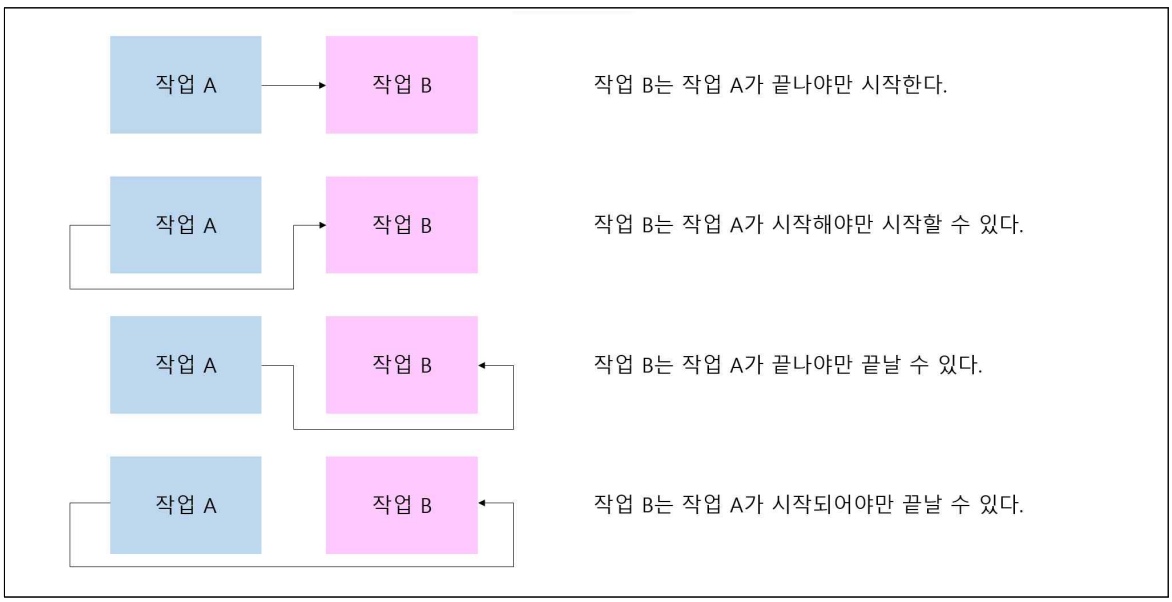
작업 목록의 가장 아래 단계인 작업 활동으로 분할하여 작성한다.

(2) 활동 목록을 작성한다.

활동 내역, 활동 식별번호, 활동 특성(선·후행 활동, 활동 간 논리적 관계, 자원 요구사항, 각종 제약, 가정, 활동 책임자, 작업수행 장소)을 작성한다.

3. 활동 순서 결정

활동 순서의 결정은 활동 간 논리적 연관성을 찾아서 문서화하는데, 활동 간 의존성을 고려하여 작성한다.



4. 활동 자원 산정

자원의 유형(인력, 장비, 자재), 수량 등을 활동 자원으로 설정하고 이를 일정 개발에 포함하여 계산한다.

5. 일정관리 활동 기간 산정

일정 관리를 위하여 각 작업 태스크(task)별로 작업 일정을 산정하여 태스크별 활동 기간을 산정한다. 각 활동을 수행하는 데 필요한 자재, 인적 자원, 장비 또는 공급품의 종류와 수량을 산정하는 프로세스로 필요한 자원의 종류와 수량, 특성을 식별하는 것이 이 프로세스의 주요 이점이다.

(1) 전문가에 의해 판단한다.

(가) 과거 유사한 프로젝트의 선례 정보에 따른 전문가 판단은 기간 산정치 정보 또는 권장하는 최대 활동 기간을 제시한다.
(나) 여러 가지 산정 방법을 결합할지 여부와 산정 방법 간 차이를 조정할 방법을 결정하는 데에도 활용이 가능하다.

(2) 유사한 산정을 실시한다.

(가) 과거 유사한 활동 또는 프로젝트의 선례 데이터를 활용하여 활동 또는 프로젝트의 기간이나 원가를 산정하는 기법이다.
(나) 과거 유사한 프로젝트의 다양한 모수(예: 기간, 예산, 규모, 가중치, 복잡성)를 향후 프로젝트에 대한 동일한 모수 또는 측정치를 산정하기 위한 기준으로 사용한다.
(다) 이 기법으로 기간을 산정할 때, 과거 유사한 프로젝트의 실제 기간이 현재 프로젝트의 기간을 산정하기 위한 기준이 된다.
(라) 프로젝트에 대해 상세한 정보가 제한적일 때 흔히 유사 기간 산정을 사용한다.
(마) 다른 기법에 비해 일반적으로 시간과 비용이 적게 드는 대신 정확도가 떨어진다.
(바) 프로젝트 전체 또는 일부분에 적용할 수 있고, 다른 산정 기법과 연동하여 사용할 수 있다.

(3) 모수에 의한 산정을 실시한다.

(가) 알고리즘을 이용하여 선례 데이터와 프로젝트 모수를 기준으로 원가 또는 기간을 계산하는 산정 기법이다.
(나) 선례 데이터와 그 외 다른 변수 간 통계적 관계를 이용하여 원가, 예산, 기간 등의 활동 모수에 대한 산정치를 계산한다.

(4) 예비 분석을 실시한다.

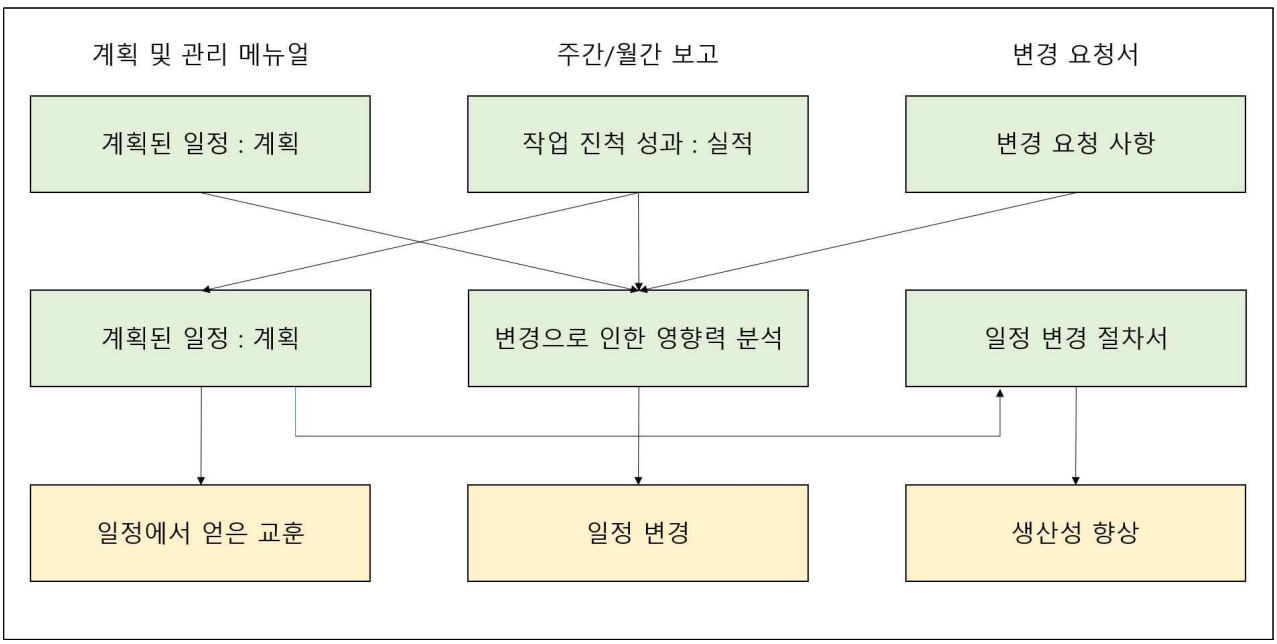
(가) 기간 산정 과정에서 일정의 불확실성을 고려하여 시간 예비비 또는 완충이라고도 하는 우발 사태 예비비를 프로젝트 일정에 포함시킬 수 있다.
(나) 허용되는 수준의 식별된 리스크와 우발 사태 또는 완화 대응책 개발에 우발 사태 예비비가 할당되며, 일정 기준선 내에서 산정된다.

6. WBS 작성 및 구축 일정 개발

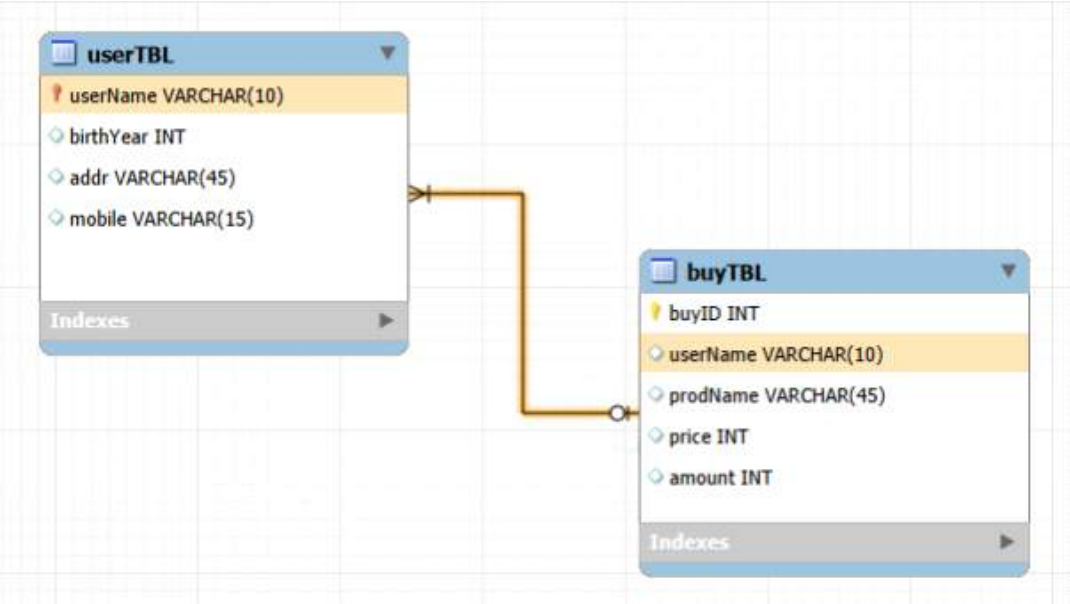
대분류	세부 활동	M+0 (1주)	M+0 (2주)	M+0 (3주)	M+0 (4주)	M+1 (1주)	M+1 (2주)	M+1 (3주)	M+1 (4주)	M+2 (1주)	M+2 (2주)	M+2 (3주)	M+2 (4주)	비고
요구사항 분석	요구사항 정의													
	데이터 항목 도출													
DB 설계	ERD 설계													
	테이블 구조 설계													
DB 구축	DB 생성													
	테이블 생성													
	사용자 계정 생성													
데이터 입력	초기 데이터 입력													
	데이터 검증													
기능 구현	CRUD 구현													
	웹 연동(PHP)													
보안 설정	사용자 권한 설정													
	SSL 암호화 적용													
테스트	기능 테스트													
	패킷 분석													
유지보수	오류 수정													
	성능 점검													

7. 일정 통제

데이터베이스 구축 작업을 하다 보면 일정 지연이 발생할 수 있다. 이에 대비하여 계획 일정 통제 기준(baseline)을 대상으로 일정 변경에 대한 통제를 실시하고, 이를 위하여 일정에 대한 영향력을 분석한다.
이는 데이터베이스 구축 작업에 수립된 일정과 실적을 비교하여 진척 상황을 모니터링하고, 실적이 일정에 비해 미진한 경우 적절한 시정 조치를 하는 과정이다.



Ⅱ. SQL 쿼리 작성



1. userTBL

- userName(최대 10자, PK, NOT NULL), birthYear, addr, mobile 저장

2. buyTBL

- buyID(자동 증가, PK), userName(FK), prodName, price, amount 저장
- userName은 userTBL의 userName 참조

3. 작성한 SQL로 모델 다이어그램 생성

※ SQL Script

```
-- -----------------------------------------------------
-- Table `modelDB`.`buyTBL`
-- -----------------------------------------------------
CREATE TABLE IF NOT EXISTS `modelDB`.`buyTBL` (
  `buyID` INT NOT NULL,
  `userName` VARCHAR(10) NULL,
  `prodName` VARCHAR(45) NULL,
  `price` INT NULL,
  `amount` INT NULL,
  PRIMARY KEY (`buyID`))
ENGINE = InnoDB;
-- -----------------------------------------------------
-- Table `modelDB`.`userTBL`
-- -----------------------------------------------------
CREATE TABLE IF NOT EXISTS `modelDB`.`userTBL` (
  `userName` VARCHAR(10) NOT NULL,
  `birthYear` INT NULL,
  `addr` VARCHAR(45) NULL,
  `mobile` VARCHAR(15) NULL,
  PRIMARY KEY (`userName`),
  CONSTRAINT `fk_userTBL_buyTBL`
    FOREIGN KEY (`userName`)
    REFERENCES `modelDB`.`buyTBL` (`userName`)
    ON DELETE NO ACTION
    ON UPDATE NO ACTION)
ENGINE = InnoDB;
```

Ⅲ. 데이터베이스 보안 구현

□ 데이터베이스 구현 방법 수행

1. Alma Linux 고정 IP 설정 및 네트워크 인터페이스 구성

ens160 인터페이스에 고정 IP, 게이트웨이, DNS를 설정하고 적용 상태를 확인한다.

```
[root@alma roror]# nmcli c modi ens160 ipv4.address 10.0.0.201/24
[root@alma roror]# nmcli c modi ens160 ipv4.gateway 10.0.0.1
[root@alma roror]# nmcli c modi ens160 ipv4.dns 10.0.0.200 8.8.8.8
Error: value for '8.8.8.8' is missing.
[root@alma roror]# nmcli c modi ens160 ipv4.method manual
[root@alma roror]# nmcli c down ens160
Connection 'ens160' successfully deactivated (D-Bus active path: /org/freedesktop/NetworkManager/ActiveConnection/2)
[root@alma roror]# nmcli c up ens160
Connection successfully activated (D-Bus active path: /org/freedesktop/NetworkManager/ActiveConnection/3)
[root@alma roror]# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: ens160: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:0c:29:58:ee:7e brd ff:ff:ff:ff:ff:ff
    altname enp3s0
    altname enx000c2958ee7e
    inet 10.0.0.201/24 brd 10.0.0.255 scope global noprefixroute ens160
       valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe58:ee7e/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

2. 파일 업로드 및 PHP 환경 구성

압축 파일(insecure.zip)을 /var/www/html에 해제하고, PHP 실행을 위해 관련 패키지를 전부 설치한다.

```
[root@alma ~]# cd /home/roror
[root@alma roror]# ls
insecure.zip  run.sh
[root@alma roror]# unzip insecure.zip
bash: unzip: command not found
[root@alma roror]# unzip insecure.zip -d /var/www/html
[root@alma roror]# dnf install php-*
```

3. common.php 파일 수정

common.php 파일에 들어가서 웹사이트가 데이터베이스에 접속할 수 있도록 host, id, pw 를 수정한다.

```
<?php
        header("Content-Type: text/html; charset=UTF-8;");

        $tb_name = "insecure_board";
        $upload_path = "upload";

        function mysql_conn() {
                $host = "10.0.0.200";
                $id = "roror";
                $pw = "qhdks12";
                $db = "pentest";

                $db_conn = new mysqli($host, $id, $pw, $db);

                return $db_conn;
        }

?>
"common.php" [dos] 18L, 314B written
```

4. 웹서버 재시작

방금 수정한 설정값이 실제 서버 운영에 즉시 반영되도록 웹 서버와 PHP 처리기를 다시 끄고 킨다.

```
[root@alma roror]# systemctl restart httpd php-fpm
```



5. PHP 환경 설정 변경

PHP 설정 파일에서 short_open_tag 옵션을 활성화하여, 기존 레거시 코드에서 사용되는 짧은 태그 형식이 정상적으로 실행되도록 구성하였다.
short_open_tag 옵션이 비활성화된 상태에서는 짧은 PHP 태그가 해석되지 않아 코드가 그대로 출력되는 문제가 발생하여 해당 옵션을 활성화함으로써 PHP 코드가 정상적으로 실행되어 화면 오류가 해결되었다.

```
[root@alma html]# vi /etc/php.ini
short_open_tag = On
```



6. 데이터베이스 사용자 생성

MariaDB에 접속한 후, 특정 IP(10.0.0.201)에서 원격 접속이 가능한 사용자 계정을 생성하였다.

```
root@roror:/home/roror# mysql
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 37
Server version: 10.11.15-MariaDB MariaDB Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> CREATE USER 'roror'@'10.0.0.201' IDENTIFIED BY 'qhdks12';
Query OK, 0 rows affected (0.011 sec)

MariaDB [(none)]> GRANT ALL PRIVILEGES ON *.* TO 'roror'@'10.0.0.201';
Query OK, 0 rows affected (0.010 sec)

MariaDB [(none)]> FLUSH PRIVILEGES;
Query OK, 0 rows affected (0.001 sec)

MariaDB [(none)]> exit
Bye
```

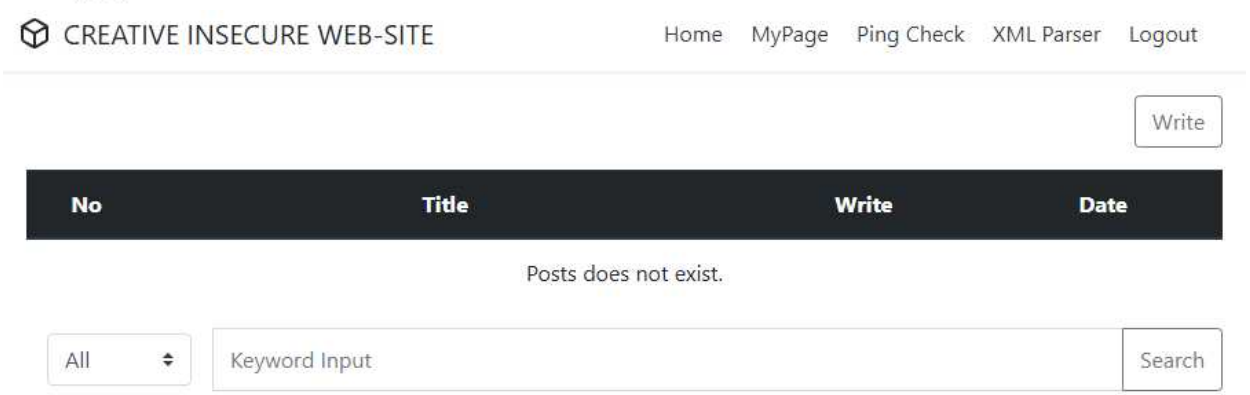


7. 사용자 권한 확인

아이디를 admin으로 로그인하면 root 계정으로 모든 권한이 부여된다. 그래서 웹에 연동이 잘 되었는지 확인하기 위해 로그인해서 보면 관리자 계정에만 생성되는 추가 기능 메뉴가 표시된다.

vi index.php

```
"]?>">MyPage</a>
        <? if($_SESSION["id"] == "admin") { ?>
        <a class="p-2 text-dark" href="index.php?page=pingcheck">Ping Check</a>
        <a class="p-2 text-dark" href="index.php?page=xmlparser">XML Parser</a>
        <? } ?>
        <a class="p-2 text-dark" href="logout.php">Logout</a>
        <? } ?>
      </nav>
    </div>
```



□ 데이터베이스 암호화 주안점 수행

1. SSL 인증서 파일 설정

MariaDB 통신 암호화를 위해 SSL 인증서 파일을 생성하고 보안 강화를 위해 MySQL 사용자만 접근 가능하도록 제한하여 인증서 유출 방지하였다.

```
root@roror:~# cd /etc/ssl
root@roror:/etc/ssl# mkdir /var/lib/mysql/ssl
root@roror:/etc/ssl# cp ca.pem  server-cert.pem  server-key.pem $_
root@roror:/etc/ssl# cd $_
root@roror:/var/lib/mysql/ssl# ls
ca.pem  server-cert.pem  server-key.pem
root@roror:/var/lib/mysql/ssl# chown -R mysql:mysql ../ssl
root@roror:/var/lib/mysql/ssl# chmod -R 700 ../ssl
root@roror:/var/lib/mysql/ssl# ls -ld $_
drwx------. 2 mysql mysql 65 Apr 20 15:04 ../ssl
root@roror:/var/lib/mysql/ssl# ls -l
total 12
-rwx------. 1 mysql mysql 2037 Apr 20 15:04 ca.pem
-rwx------. 1 mysql mysql 1891 Apr 20 15:04 server-cert.pem
-rwx------. 1 mysql mysql 1704 Apr 20 15:04 server-key.pem
```

2. MariaDB 설정 파일 수정

MariaDB 설정 파일(my.cnf)에 SSL 관련 항목을 추가하여 SSL 인증서 경로를 지정하고 DB 서버 재시작으로 설정을 적용하였다.

```
[mysqld]
datadir=/var/lib/mysql
socket=/var/lib/mysql/mysql.sock
log-error=/var/log/mariadb/mariadb.log
pid-file=/run/mariadb/mariadb.pid
ssl-ca=/var/lib/mysql/ssl/ca.pem
ssl-cert=/var/lib/mysql/ssl/server-cert.pem
ssl-key=/var/lib/mysql/ssl/server-key.pem
require_secure_transport=OFF
```

=> systemctl restart mariadb

3. SSL 적용 여부 확인

MariaDB에서 SSL 관련 변수 확인하여 OpenSSL은 사용 가능하지만 SSL 적용은 아직 비활성 상태인 것을 확인하였고, 암호화 통신이 적용되지 않았음을 확인하였다.

```
MariaDB [(none)]> show variables like '%ssl%';
+----------------------+---------------------------+
| Variable_name        | Value                     |
+----------------------+---------------------------+
| have_openssl         | YES                       |
| have_ssl             | DISABLED                  |
| ssl_ca               |                           |
| ssl_capath           |                           |
| ssl_cert             |                           |
| ssl_cipher           |                           |
| ssl_crl              |                           |
| ssl_crlpath          |                           |
| ssl_key              |                           |
| version_ssl_library  | OpenSSL 3.5.1 1 Jul 2025  |
+----------------------+---------------------------+
10 rows in set (0.004 sec)

MariaDB [(none)]> show status like '%ssl_cipher%';
+---------------+-------------------------
```

5. 인증서 클라이언트 전송

칼리(클라이언트)에서 SSL 접속을 위해 CA 인증서를 서버에서 복사해 클라이언트에서도 서버 인증 검증 가능하도록 구성하였다.

```
root@roror:/var/lib/mysql/ssl# scp ca.pem kali@10.0.0.133:/home/kali
The authenticity of host '10.0.0.133 (10.0.0.133)' can't be established.
ED25519 key fingerprint is SHA256:mymH3nLCQ0rzFrAWWyROf7C6rA4dlxXJPCU3pMTt+8A.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.0.0.133' (ED25519) to the list of known hosts.
kali@10.0.0.133's password:
ca.pem                                                100% 2037     4.1MB/s   00:00
```

6. SSL 접속 사용자 설정

SSL을 반드시 사용하도록 사용자 권한 설정하여 해당 사용자는 반드시 암호화 통신으로만 접속 가능하다.

```
root@roror:/var/lib/mysql/ssl# mysql
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 7
Server version: 10.11.15-MariaDB MariaDB Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> grant all privileges on *.* to hacker@'%' identified by 'qhdks12' require ssl;
Query OK, 0 rows affected (0.001 sec)

MariaDB [(none)]> GRANT ALL PRIVILEGES ON *.* TO 'roror'@'%' IDENTIFIED BY 'qhdks12' ;
Query OK, 0 rows affected (0.001 sec)

MariaDB [(none)]> FLUSH PRIVILEGES;
Query OK, 0 rows affected (0.001 sec)

MariaDB [(none)]> quit
Bye
```

root@roror:~# systemctl restart mariadb

7. 비암호화 접속 테스트

SSL 없이 접속 시도하니 정상 접속되었다.

```
root@kali:~# mysql -uroror -p -h roror.co.kr --ssl=0
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 18
Server version: 10.11.15-MariaDB MariaDB Server

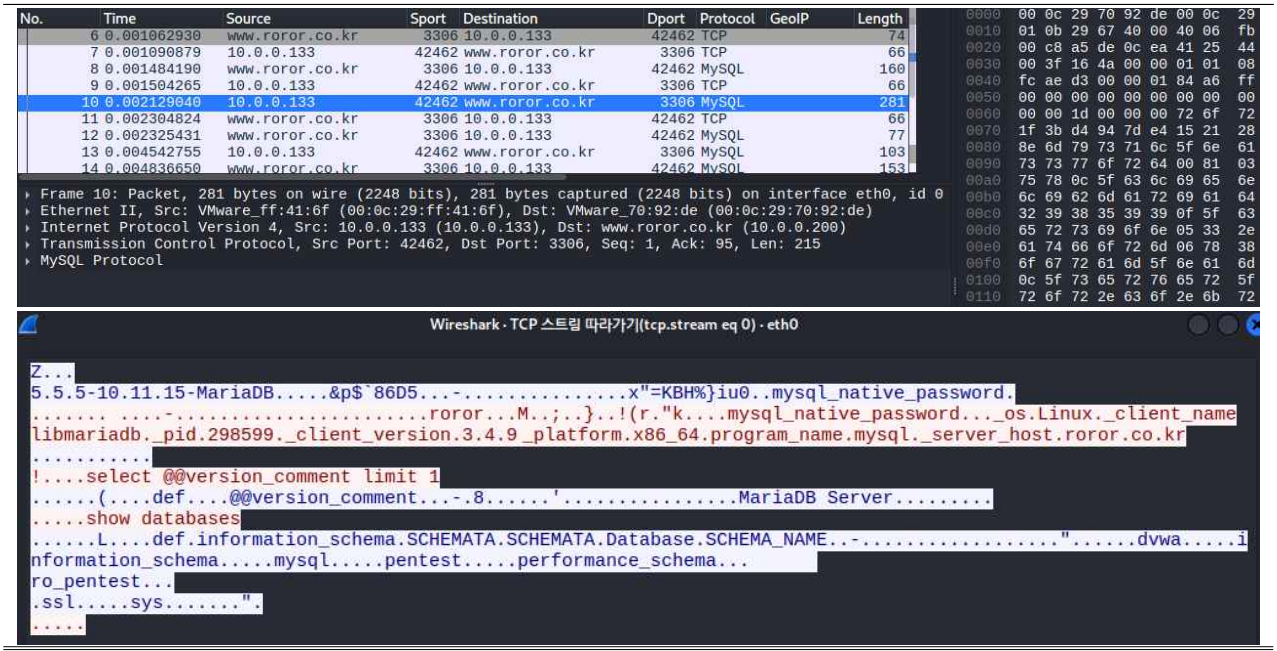
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> show databases;
```

8. 패킷 분석

암호화 미적용 상태이기 때문에 데이터가 그대로 노출되어 MySQL 인증 정보가 노출되었고 쿼리 내용 평문 확인이 가능하다.



9. SSL 적용 접속 테스트

SSL 옵션을 사용하여 MariaDB 서버에 접속을 수행하였다. 서버 인증서 검증 생략하고 SSL 기반으로 암호화된 연결 수행하여 정상적으로 MariaDB 접속 성공하였다.

```
root@kali:~# mysql -uroror -p -h roror.co.kr --skip-ssl-verify-server-cert
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 16
Server version: 10.11.15-MariaDB MariaDB Server

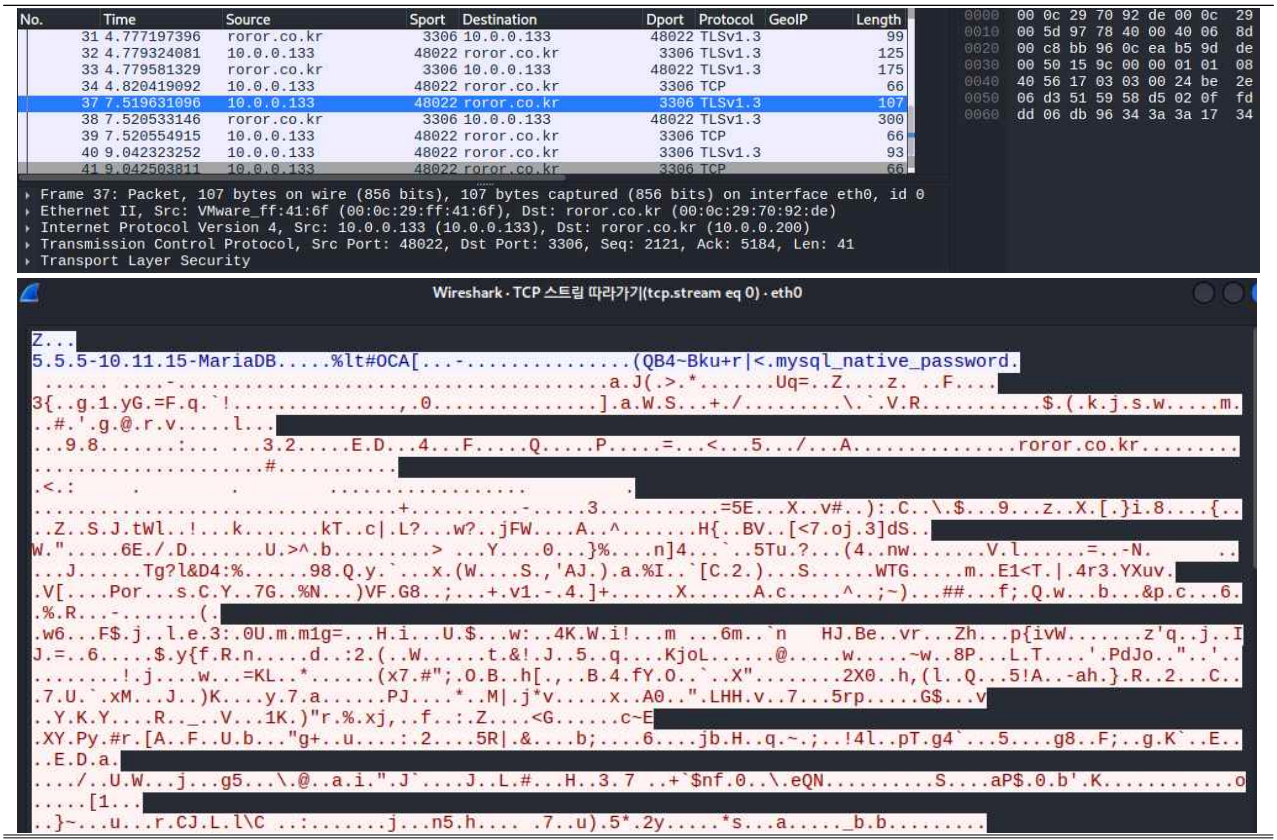
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> show databases;
```

10. 패킷 분석

TLS 프로토콜 사용이 확인되었고, 기존과 달리 내부 데이터가 암호화되어 쿼리문 및 인증 정보 식별이 불가하여 데이터 기밀성이 확보되었다.



IV. 데이터베이스 보안 구현 테스트

기본 정보	**결함 ID**	bug123	**시스템명**	Database
	결함 제목	데이터 암호화가 불규칙적으로 되고 있음		
	등록자 (발견자)	홍길동	**등록 일자**	2026.04.23
	결함 유형	기능 결함	**테스트 ID**	test123
	심각도	높음	**우선순위**	긴급
	설명	1. 데이터 암호화가 불규칙적으로 실시됨 2. 데이터 값이 일정하지 않음		
	테스트 환경 정보	1. AP 환경 2. 설치 DBMS v3.0		
	첨부파일	없음		
상태 정보	**결함 상태**	결함 종료		
	할당자	김부장	**할당 일자**	2026.04.23
처리 정보	**처리 이력1**	1. 데이터 암호화 설정 환경 수정 2. 암호화 기능이 정상적으로 동작되는지 여부 확인		
	처리 이력2	1. 확인 결과 : 이상 발생 없음 2. 결함 수정 확인 완료		